

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

Mass Assignment Extra Fields Rejected Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	Mass assignment
Result Type	Attack rejected / control validated
Evidence Report File	12-mass-assignment-extra-fields-rejected-evidence-report.pdf
Testing Phase	Object Property Assignment Testing
Tool / Component	Postman / API Request Modification
OWASP / Security Mapping	API3:2023 Broken Object Property Level Authorization
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

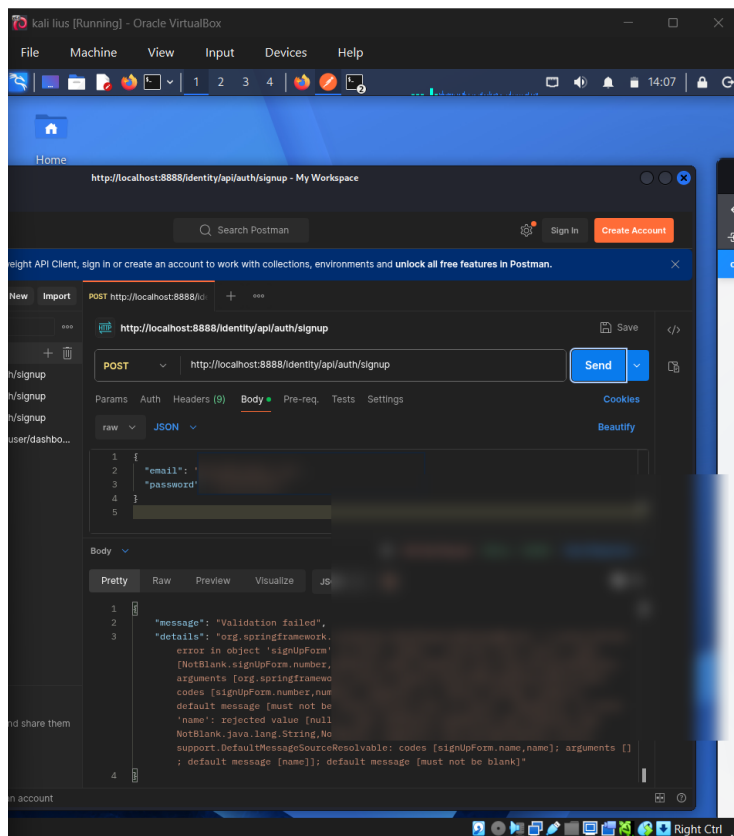


Figure 1 - Embedded screenshot evidence for: Mass assignment

What this evidence proves

The evidence shows a modified request with extra fields being rejected or not accepted as privilege-changing input. This validates a control rather than proving a vulnerability.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	Object Property Assignment Testing
Tool / Component	Postman / API Request Modification
Assessment Objective	Test whether the API accepts unexpected JSON fields such as role, isAdmin, balance, or privilege-related properties.
Result Type	Attack rejected / control validated
OWASP / Security Mapping	API3:2023 Broken Object Property Level Authorization

Why this evidence matters

Mass assignment occurs when APIs bind all client-supplied JSON fields directly to backend objects. Secure APIs should allowlist accepted fields and reject privileged properties.

Command / workflow used

```
Send normal request
Add unexpected fields such as role, isAdmin, credit, privilege
Submit modified request
Observe whether the server rejects, ignores, or applies extra fields
```

Sanitized output style

```
Submitted body includes extra test fields: <REDACTED>
Observed response: rejected / control validated
Privilege change: not accepted
```

3. Professional Interpretation

This evidence row should be interpreted as: **Attack rejected / control validated**.

If mass assignment were accepted, attackers could self-assign admin roles, change balances, modify ownership, or set internal flags. In this lab evidence, rejection indicates safer behaviour for the tested request.

Assessor notes

This should be documented as attack rejected / control validated.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Important reporting distinction

This row should not be exaggerated as a vulnerability. The correct professional wording is that the attack attempt was performed and the application rejected it, which validates a security control for this specific test case.

4. Risk, Impact, and Remediation Guidance

Risk perspective

If mass assignment were accepted, attackers could self-assign admin roles, change balances, modify ownership, or set internal flags. In this lab evidence, rejection indicates safer behaviour for the tested request.

Recommended remediation / hardening actions

- Use allowlisted request schemas.
- Reject unknown fields.
- Separate user input models from database models.
- Validate fields server-side.
- Log attempts to submit privileged properties.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Test emails.
- Passwords.
- Request tokens.
- User IDs and submitted JSON values.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

`[Mass assignment](./reports/evidence/12-mass-assignment-extra-fields-rejected-evidence-report.pdf)`

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.